

Day: 20

* ARP Review

- ARP (Address Resolution Protocol) translates IP addresses → MAC address within a local network. Your PC broadcasts "Who has 192.168.1.1?" and the router replies "That's me — AA:BB:CC:DD:EE:FF".

* What is ARP Poisoning?

- ARP has no authentication — any device can send an ARP reply claiming any IP. Attackers exploit this to redirect traffic through their machine.

- Normal:

PC-A → Router → Internet

- After ARP Poisoning:

PC-A → ATTACKER → Router → Internet

↑

Attacker reads all traffic (MITM)

* How it works:

- 1) Attacker sends fake ARP reply to PC-A: "192.168.1.1 (router) is at My Mac".

- 2) PC - A updates its ARP cache - now sends all traffic to attacker.
- 3) Attacker forwards traffic to real router (so victim doesn't notice).
- 4) Attacker reads everything in between → Man in the Middle (MITM).

* ARP Poisoning Signs in Wireshark

- 1) Same MAC → Attacker claiming to be multiple IPs → multiple hosts
- 2) Same IP → ARP cache being multiple MAC → poisoned
- 3) High ARP rate → ARP Flood / Storm
- 4) Gratuitous ARP → Unsolicited ARP reply — suspicious
- 5) ARP reply with no request → Nobody asked — why is it replying?

* Key Wireshark filter:

arp.duplicate — address — detected

- Wireshark automatically flags ARP poisoning! Also look for:

arp.opcode == 2 (ARP replies only)

* What is Gratuitous ARP?

- A Gratuitous ARP is when a device sends an ARP reply without anyone asking. It announces:

"I am 192.168.1.1 and my MAC is XX:XX:XX:XX:XX:XX"

- Legitimate use: Device coming online, updating everyone's cache.
- Malicious use: Attacker poisoning everyone's ARP cache at once.
- In Wireshark: Src IP $\neq$ Dst IP in ARP packet = Gratuitous ARP.

* What is DHCP?

- DHCP (Dynamic Host Configuration Protocol) automatically assigns IP addresses to devices joining a network.

* DHCP DORA process:

Client $\rightarrow$ DHCP Discover (broadcast "I need an IP!")

Server $\rightarrow$ DHCP offer (Unicast: "Here, take 192.168.1.50")

Client $\rightarrow$ DHCP Request (broadcast: "Yes,

I'll take that IP")

Server → DHCP ACK Unicast: "Confirmed
I It's yours.")

Message	Direction	Purpose
Discover	Client → Broadcast	Find DHCP server
offer	Server → Client	offer IP address
Request	Client → Broadcast	Accept the offer
ACK	Server → Client	Confirm assignment

* DHCP Attacks

1) DHCP Starvation:

Attacker sends thousands of fake DHCP Discover packets with spoofed MAC addresses → exhausts all available IP address → legitimate clients can't get IPs (DoS).

• Signs in Wireshark:

1) Huge number of DHCP Discover

packets.

2) All from different MAC addresses

3) DHCP pool exhausted — server stops responding.

Filter: `bootp.option.type == 53 and bootp.option.dhcp == 1`
(DHCP Discover packets only)

2) Rogue DHCP Server:

- Attacker's IP as the default gateway (all traffic goes through attacker).

Attacker sets up their own DHCP server → legitimate clients receive:

- Attacker's IP as the DNS server (attacker controls DNS = controls everything).

- Signs in Wireshark:

1) Two different servers responding to DHCP Discover.

2) DHCP offer from unexpected IP.

3) Clients getting gateway = attacker's IP.

Filter: `bootp.option.type == 53 and`

bootp.option.dhcp == 2
(DHCP offer packets only)

* ARP Poisoning vs Rogue DHCP

Attack	Layer	Method	Goal
ARP Poisoning	Layer 2	Fake ARP replies	MITM existing connections
Rogue DHCP	Layer 3	Fake DHCP server	MITM new connections
DHCP Starvation	Layer 3	Flood DHCP Discover	DoS — no IPs available

Both achieve the same result — the attacker sits between victim and router — but via different methods.

* Detecting These Attacks in Wireshark

1) ARP Poisoning:

arp → all ARP traffic
all ARP traffic

arp.opcode == 2 → replies only

arp.duplicate-address-detected →

auto - flagged!

2) DHCP Attacks:

bootp → all DHCP traffic

bootp.option.dhcp == 1 → DHCP Discover

bootp.option.dhcp == 2 → DHCP Offer

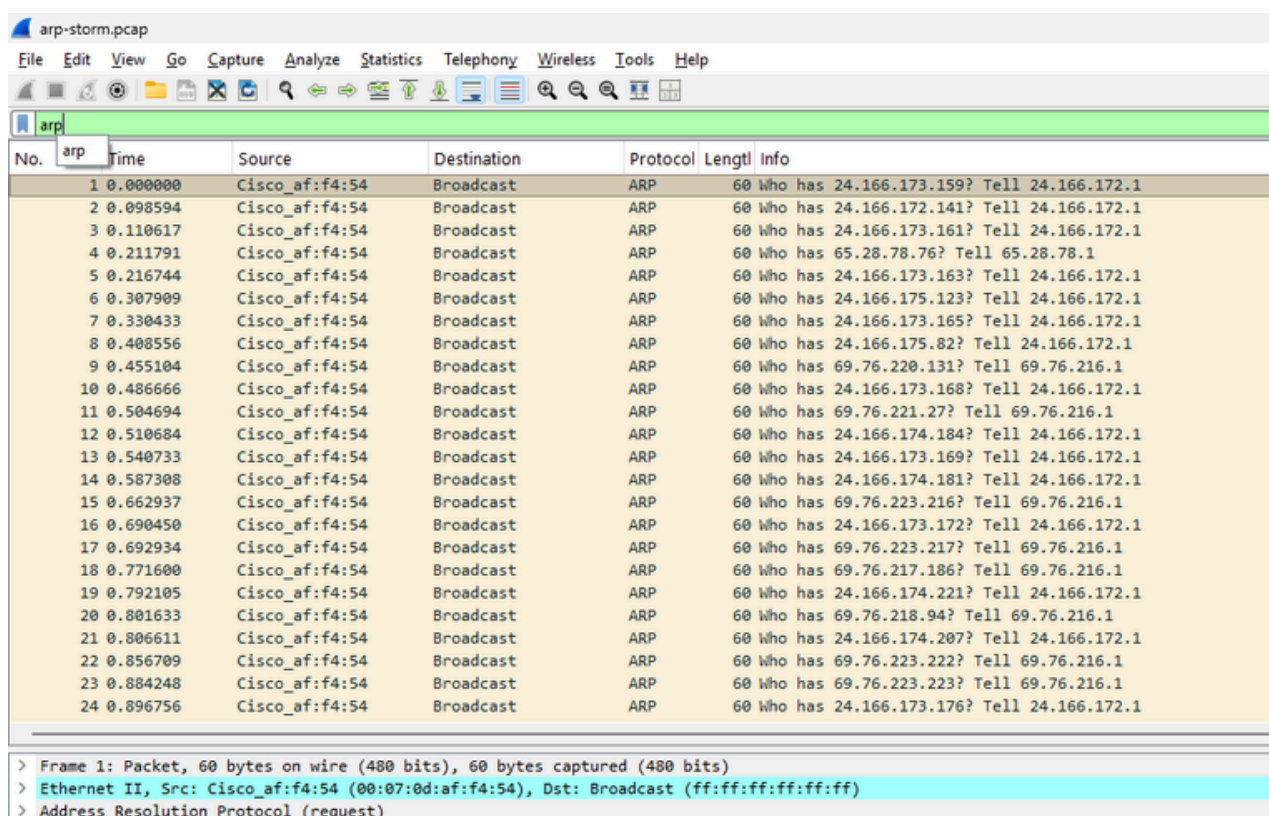
bootp.option.dhcp == 5 → DHCP ACK

* DFIR Significance

- ARP poisoning is the most common LAN attack — used for credential theft, session hijacking.
- Rogue DHCP enables full network interception of all new connections
- Both are undetectable to victims without network monitoring.
- Dynamic ARP Inspection (DAI) on managed switches prevents ARP poisoning.
- DHCP Snooping on managed switches prevents rogue DHCP servers.

LAB — The Full Solo Investigation:

1. Go to
<https://wiki.wireshark.org/SampleCaptures>
2. Download arp-storm.pcap
3. Open in Wireshark
4. Apply filter:



arp-storm.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

arp

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.173.159? Tell 24.166.172.1
2	0.098594	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.172.141? Tell 24.166.172.1
3	0.110617	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.173.161? Tell 24.166.172.1
4	0.211791	Cisco_af:f4:54	Broadcast	ARP	60	Who has 65.28.78.76? Tell 65.28.78.1
5	0.216744	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.173.163? Tell 24.166.172.1
6	0.307909	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.175.123? Tell 24.166.172.1
7	0.330433	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.173.165? Tell 24.166.172.1
8	0.408556	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.175.82? Tell 24.166.172.1
9	0.455104	Cisco_af:f4:54	Broadcast	ARP	60	Who has 69.76.220.131? Tell 69.76.216.1
10	0.486666	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.173.168? Tell 24.166.172.1
11	0.504694	Cisco_af:f4:54	Broadcast	ARP	60	Who has 69.76.221.27? Tell 69.76.216.1
12	0.510684	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.174.184? Tell 24.166.172.1
13	0.540733	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.173.169? Tell 24.166.172.1
14	0.587308	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.174.181? Tell 24.166.172.1
15	0.662937	Cisco_af:f4:54	Broadcast	ARP	60	Who has 69.76.223.216? Tell 69.76.216.1
16	0.690450	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.173.172? Tell 24.166.172.1
17	0.692934	Cisco_af:f4:54	Broadcast	ARP	60	Who has 69.76.223.217? Tell 69.76.216.1
18	0.771600	Cisco_af:f4:54	Broadcast	ARP	60	Who has 69.76.217.186? Tell 69.76.216.1
19	0.792105	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.174.221? Tell 24.166.172.1
20	0.801633	Cisco_af:f4:54	Broadcast	ARP	60	Who has 69.76.218.94? Tell 69.76.216.1
21	0.806611	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.174.207? Tell 24.166.172.1
22	0.856709	Cisco_af:f4:54	Broadcast	ARP	60	Who has 69.76.223.222? Tell 69.76.216.1
23	0.884248	Cisco_af:f4:54	Broadcast	ARP	60	Who has 69.76.223.223? Tell 69.76.216.1
24	0.896756	Cisco_af:f4:54	Broadcast	ARP	60	Who has 24.166.173.176? Tell 24.166.172.1

> Frame 1: Packet, 60 bytes on wire (480 bits), 60 bytes captured (480 bits)
> Ethernet II, Src: Cisco_af:f4:54 (00:07:0d:af:f4:54), Dst: Broadcast (ff:ff:ff:ff:ff:ff)
> Address Resolution Protocol (request)